Name : Saiba Khan

Case Study - 2

Securing the University Examination System

A university uses an operating system-based examination management system to store student records, examination marks, faculty details, and question papers. The system has three main user groups: Students, Faculty, and Administrators. Student should be able to view only their own marks and download permitted learning ~~matter~~ materials. Faculty members need to view students records and enter or modify marks. Administrators manage user accounts, permissions, and system configuration.

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account student07 has ~~three~~ three failed login attempts.
- At 10:03, student07 successfully logs in.
- At 10:04, student07 attempts to open ExamMarks_CS_Y1 which contains marks for an entire class.
- At 10:05, the system records an attempted modification of ExamMarks.xlsx by student07.
- At 10:15, faculty modifies marks in ExamMarks.xlsx and saves the file successfully.
- At 10:20, an administrator discovers that a former faculty member's account is still active.
- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

PAGE No.
DATE / /

The university wants to protect confidentiality, Integrity, and availability; prevent unauthorized access; maintain accountability; and investigate suspicious activity. You are asked to recommend appropriate operating system access-control, security-administration, and auditing measures.

Questions

Q.1 Identify the main security problems in the case study. (4 marks)
List at least four risks or weeknesses indicated by the scenario.

Q.2 Explain the difference between authentication and authorization using student 7 as an example. (4 marks)
Distinguish identity verification from Permission checking.

Q.3 Recommend an access-control policy for Students, Faculty, and Administrators. Justify your choice. (5 marks)
Consider how Permissions should be assigned and managed.

Q.4 Prepare a suitable Access Control List (ACL) for ExamMarks.xlsx. (5 marks)
Specify appropriate Read, write, and Delete Permission for each user group.

Q.5 Explain how the the Principle of Least Privilege should be applied in this system. (4 marks)

state what each group needs to do and which permissions should be removed

Q.6 Interpret the audit events from 10:00 to 10:05. What should the security team do next? (5 marks)
Explain why the sequence is suspicious without assuming that it proves an attack.

Q.7 Identify at least five events that should be recorded in the audit logs. (3 marks)
Include login, file, account, permission, and/or administrative events.

Q.8) Explain why the audit logs must be protected and recommend two ways to protect them. (3 marks)
Consider unauthorized modification, deletion, and investigation

Q.9) What action should be taken regarding the former faculty members' active accounts? Explain. (3 marks)
Relate your answer to account management and access removal.

Q.10) Suggest a practical incident-response and corrective-action plan for the university. (4 marks)
Include investigation, access review, policy changes, and follow-up monitoring.

Answers (Case study 2)

Ans 1 The main security problems in the university access control system are:

a) Weak Authentication: The system may not properly verify the identity of users before granting access.

b) Excessive Permissions: Students, faculty, administrators may have unnecessary access to sensitive data and resources.

c) Unauthorised Access: Students may access confidential information or resources without permissions.

d) Lack of Auditing & Monitoring: Activities may go unnoticed if access logs are not properly monitored or reviewed.

Ans 2 Authentication is the process of determining what an authenticated user is allowed to access or do.

Ans 3 The university should apply Role Based Access Control (RBAC), in which permissions are assigned according to the user's role.

i) Students: can view their own academic records, access course materials & submit assignments.

(ii) Faculty : can upload course materials manage assignments, and enter or update marks for there assigned courses.

(iii) Administrators: can manage user accounts, assign roles, configure security settings & monitor system activities.

Role Based Access Control simplifies permission management, Prevents unauthorised access, reduces security risks & ensures that users can access only the resources required for there roles

Ans) The following ACL (Access Control Lists) are:

User	Read	write	Delete
Students	Yes(own results only	No	No
Faculty	Yes(assigned courses only	Yes(assigned courses only	No
Administrators	yes	Yes(authorised changes only	Yes

This Access control list protects the confidentiality and integrity of examination results

The Principle of least Privilege (POLP) states that every user should receive only the minimum

DATE / /

Permissions necessary to perform their duties. It should be applied as follows:

(i) Students: Receives permissions to view their own results & access learning materials, without permission to modify examination record.

(ii) Faculty: Receive access only to the courses & students records they are responsible for.

(iii) Administrators: Receive only the administrative privileges required for their duties.

The principles reduces unauthorised access, accidental changes, & potential security threats.

PoLP reduces the risk of unauthorised access, prevents accidental or malicious modification of examination records, also ensures every user has the only access required to perform their duties.

Ans6 The user tries to attempt 3 failed login attempts at 10:00, at 10:30 by successfully login in 10:04 students of attempts to access Exam Marks.xlsx, which contains the entire class's marks. A 10:05 attempt to modify the exam file.

The security team asks the following actions

DATE / /

- Verify the account: check whether the login was legitimate or not.
- Block unauthorized access: by enforcing proper access permissions.
- check file Integrity: To confirm whether any marks were changed.
- Secure audit logs: by storing them separately with restricted access to prevent temperling.

Ans: The following events should be recorded in audit logs:

(i) Login & Logout events: Records when the users login in & log out of the university system.

(ii) Failed login attempts: Records unsuccessful login attempts to identify possible unauthorized access.

(iii) Account management events: Records the creation, modification, & deletion of user accounts.

(iv) Permission changes: Records changes to user roles & access privileges.

(v) Administrative Activities: Records important actions performed by system administrators, such as changing system settings or accessing sensitive data.

PAGE No.
DATE / /

Ans8) Audit logs must be protected because they contain important records of user activities & security events, unauthorised modification or deletion of these logs can hide suspicious activities & make investigations difficult.

- Restrict Access: Allow only authorised administrators to access audit logs and role based access controls.

- Prevent modifications & deletion: use tamper resistant storage, encryption and regular backups to protect logs from unauthorised changes or loss.

Ans9) The university should immediately disable the former faculty members account & revoke their access to university systems. It should also terminate active sessions, review the accounts previous activities. This is important as former faculty members no longer require access to university resources. Disabling inactive accounts reduces the risk of unauthorised access data misuse.

Ans10 Investigate: Reviewing audit logs, verify student's activities, & check whether any marks were changed without authorisation.

PAGE No.
DATE / /

- Review access: Disable the former faculty's member account & examine the permissions of students, faculty & administrators.